

NARRATIVA EXPLICATIVA

El Porqué de Cada Pregunta: Contexto, Relevancia y Evidencia Empírica

CIA Triad Survey Kit 2025 — Documento de Soporte Intelectual

"Una encuesta sin narrativa es un formulario. Una encuesta con narrativa es un instrumento de conocimiento.

La diferencia entre ambos la mide la calidad de las decisiones que genera."

INTRODUCCIÓN: LA ENCUESTA COMO ACTO EPISTEMOLÓGICO

Esta narrativa cumple una función doble: por un lado, explica al equipo investigador el fundamento conceptual y empírico de cada bloque de preguntas; por otro, puede servir como material de acompañamiento para sensibilizar a los directivos que cumplimentan la encuesta sobre por qué las preguntas son las que son, y no otras más cómodas.

Porque, seamos honestos: una encuesta de madurez en ciberseguridad que solo hiciera preguntas cuya respuesta no incomodara sería tan útil como un detector de incendios que solo se activa cuando el edificio ya arde completamente.

BLOQUE 0: EL PERFIL COMO CONTEXTO, NO COMO ADORNO

Las preguntas de perfil organizacional no son burocracia de apertura. Son las variables de control que permiten transformar una masa de respuestas individuales en conocimiento estructurado y comparativo.

¿Por qué importa el sector? Las amenazas no son democráticas. El sector financiero fue el objetivo del 34% de los incidentes en operadores esenciales en España en 2025 (INCIBE, Balance 2025). La administración pública concentra el 38,2% de los blancos de hackactivismo en la UE (ENISA Threat Landscape 2025). La manufactura es el sector más golpeado por ransomware en España ese mismo año. Sin sectorización, los datos son promedios que describen perfectamente a nadie.

¿Por qué importa el tamaño? Las microempresas y PYMEs representan el 99,8% del tejido empresarial español. Son también las más vulnerables y las menos estudiadas en los informes de grandes consultoras, que tienden a sesgar sus muestras hacia Fortune 500. Este instrumento aspira a corregir ese desequilibrio.

¿Por qué preguntar sobre el CISO? El 61% de las organizaciones globales siguen sin CISO formal (Cisco CRI 2025). En España, la brecha es aún mayor en PYMEs. La presencia o ausencia de esta figura es el predictor individual más robusto de madurez en ciberseguridad, según múltiples estudios.

BLOQUE 1: CONFIDENCIALIDAD — LA PRIVACIDAD COMO ARQUITECTURA

La Paradoja del Acceso

El mayor enemigo de la confidencialidad no es el hacker externo con capucha en un sótano oscuro. Es la acumulación silenciosa de privilegios de acceso que nadie revisa, la cuenta del empleado que se fue hace dos años y sigue activa, la hoja de cálculo compartida en OneDrive con datos de clientes accesible "temporalmente" desde 2019.

P1.1-P1.6 (MFA y Gestión de Accesos): Las credenciales robadas estuvieron presentes en el 22% de las brechas globales en 2025 (Verizon DBIR 2025). El phishing, primer vector de acceso con el 16% de brechas según IBM, tiene en las credenciales su botín máspreciado. La MFA resistente al phishing (FIDO2) no es una opción avanzada: es el umbral mínimo razonable en 2025 para sistemas de alta criticidad.

La pregunta P1.5 sobre PAM está formulada con una opción deliberadamente incómoda: "cuentas de administrador compartidas sin rotación". No por humor negro, sino porque esta práctica — documentada en múltiples brechas de alto perfil— sigue siendo más común de lo que cualquier CISO admitiría en público. La honestidad en la respuesta es la única forma de que el diagnóstico sea real.

El Cifrado: Necesario pero no Suficiente

P1.7-P1.9 (Cifrado y PQC): El cifrado de datos en reposo es una medida básica de confidencialidad, pero su eficacia depende críticamente de la gestión de claves. Un AES-256 con claves almacenadas en texto plano junto a los datos cifrados es, en términos de seguridad efectiva, poco más que un sobre cerrado con el candado dibujado en la solapa.

La pregunta P1.9 sobre criptografía post-cuántica puede parecer prematura. No lo es. El ataque "Harvest Now, Decrypt Later" (HNDL) —capturar datos cifrados hoy para descifrarlos cuando los ordenadores cuánticos sean suficientemente potentes— afecta al 67% de las organizaciones evaluadas en un estudio de 847 implementaciones criptográficas (Society, 2025). La decisión de cuándo migrar a PQC es estratégica; la de si migrar, no lo es.

Shadow AI: El Agujero Negro de la Confidencialidad Moderna

P1.14-P1.15 (Shadow AI): Las preguntas sobre IA no supervisada son las más novedosas del instrumento y, posiblemente, las más relevantes para el período 2025-2027. El 63% de las organizaciones carecen de políticas de gobernanza para Shadow AI (IBM Cost of Data Breach 2025). Cada empleado que copia un contrato o un informe financiero en ChatGPT sin política corporativa que lo regule está, potencialmente, exfiltrando datos confidenciales a un tercero sin evaluar las implicaciones del RGPD.

La opción "Hemos prohibido todo sin alternativa corporativa" en P1.15 no es una opción segura: es la garantía del uso clandestino. Las prohibiciones sin alternativa generan exactamente el shadow IT que pretenden eliminar.

BLOQUE 2: INTEGRIDAD — LA EXACTITUD COMO VALOR

El Problema de Medir lo Ausente

La integridad es el pilar más difícil de medir porque mide, en esencia, ausencias: la ausencia de modificaciones no autorizadas, la ausencia de corrupción de datos, la ausencia de manipulación subrepticia. Los indicadores de integridad son, filosóficamente, indicadores de lo que no ha ocurrido.

Esta dificultad ontológica tiene consecuencias prácticas: las organizaciones tienden a invertir menos en controles de integridad que en controles de confidencialidad y disponibilidad, precisamente porque el daño por integridad comprometida puede ser silencioso durante meses o años antes de manifestarse.

P2.1-P2.2 (FIM y Hash): La pregunta sobre el algoritmo de hash es, en apariencia, técnica. En realidad, es un indicador de deuda técnica. MD5 fue declarado criptográficamente roto en 2008. SHA-1 fue formalmente deprecado por NIST en 2022. Su presencia en entornos de producción en 2025 es un síntoma de gestión del ciclo de vida tecnológico deficiente, no de preferencia técnica informada.

El Parcheo: La Vacuna que Nadie Quiere Ponerse

P2.3-P2.5 (Gestión de Vulnerabilidades): El dato del ENISA NIS Investments 2025 es contundente: el 28% de las organizaciones europeas tarda más de tres meses en parchear vulnerabilidades críticas. En el mundo del CVSS ≥ 9.0 , tres meses es un período en el que una vulnerabilidad pasa de "publicada" a "explotada masivamente" varias veces.

El caso específico de los dispositivos de borde (P2.4) merece atención especial: el Verizon DBIR 2025 registró un aumento de 8 veces en el uso de vulnerabilidades de edge/VPN como vector de acceso inicial, con solo el 54% parcheados en el momento del ataque. La pregunta no es si los atacantes saben de esta estadística. Es si los defensores actúan en consecuencia.

La Cadena de Suministro: El Talón de Aquiles de la Integridad Moderna

P2.10-P2.12 (Supply Chain): El incidente SolarWinds (2020) no fue un rayo en cielo despejado; fue la expresión más visible de un riesgo sistémico que sigue creciendo. En 2025, el 30% de las brechas globales involucraron a terceros (Verizon DBIR 2025), el doble respecto al año anterior.

La pregunta P2.11 sobre SBOM (Software Bill of Materials) es especialmente relevante para el contexto español: la Directiva NIS2 y el EU Cyber Resilience Act están impulsando la obligatoriedad del SBOM para productos digitales en el mercado europeo. Las organizaciones que no lo hayan iniciado en 2025 afrontarán presión regulatoria creciente a partir de 2026.

Integridad en la Era de la IA

P2.13 (Data Poisoning): El envenenamiento de datos —la manipulación maliciosa de los datos de entrenamiento de modelos de IA— representa una amenaza emergente de integridad con características únicas: los efectos pueden ser sutiles, difícilmente detectables y de alcance sistémico si el modelo afectado está en producción. La inclusión de esta pregunta anticipa una tendencia regulatoria ya visible en el EU AI Act, que establece requisitos de integridad de datos para sistemas de IA de alto riesgo.

BLOQUE 3: DISPONIBILIDAD — EL DERECHO A ESTAR OPERATIVO

La Tiranía de las Horas de Inactividad

La disponibilidad es el pilar más visible de la tríada CIA porque sus fallos son los más inmediatos y cuantificables. Un sistema caído es un coste por hora que cualquier CFO puede calcular. Un dato exfiltrado puede tardar años en manifestarse en pérdidas; un sistema paralizado es pérdida inmediata y medible.

P3.1-P3.6 (Continuidad y Backups): La regla 3-2-1 de copias de seguridad es uno de los pocos principios de disponibilidad que ha demostrado su valor de forma universal y repetida. Y sin embargo, los incidentes de ransomware siguen siendo efectivos porque las organizaciones o no tienen copias, o tienen copias conectadas permanentemente a la red (y por tanto cifradas junto al resto del sistema), o tienen copias que nunca han verificado que son restaurables.

La pregunta P3.2 sobre frecuencia de pruebas DRP incluye la opción "Solo cuando ocurre un incidente real" no como sarcasmo, sino como reconocimiento de una realidad documentada: muchas organizaciones descubren que su plan de recuperación no funciona exactamente cuando más lo necesitan.

El SOC: De Lujo a Necesidad

P3.7-P3.9 (Monitorización y Tiempos de Respuesta): El Tiempo Medio de Detección global en 2025 es de 158 días (IBM Cost of Data Breach 2025). Este dato, repetido en este kit en múltiples contextos, merece reflexión: en 158 días, un atacante con acceso a los sistemas puede exfiltrar, modificar, destruir y cubrir sus huellas con una comodidad que cualquier intruso físico envidiaría.

La opción "Nos enteramos de los incidentes por los propios usuarios" no es hiperbólica: es el método de detección real de una fracción significativa de incidentes en organizaciones sin SOC. El helpdesk como primer sistema de detección es un modelo de seguridad que tiene el mérito de la honestidad accidental.

El Ransomware: El Termómetro de la Disponibilidad

P3.10-P3.11 (Ransomware): Los municipios de Melilla y Villajoyosa (2025) son los casos más visibles en España de lo que significa un RTO efectivo de dos semanas en una administración pública. Los ciudadanos que necesitaban certificados, gestiones o servicios durante ese período no tenían acceso. La disponibilidad, en ese contexto, no es un KPI técnico: es un derecho ciudadano.

La pregunta sobre la postura ante el pago del rescate (P3.11) es delicada pero necesaria. La política de no pago reduce los incentivos sistémicos del ransomware como modelo de negocio criminal. El 64% de las víctimas globales rechazaron pagar en 2025 (Verizon DBIR 2025). Involucrar a las fuerzas del orden redujo los costes de la brecha en aproximadamente \$1 millón por caso (IBM 2025).

BLOQUE 4: EXTENSIONES — AUTENTICIDAD Y NO REPUDIO

Las preguntas de este bloque corresponden a las dimensiones adicionales que el ENS español ya incorpora desde 2022: autenticidad (garantía de que algo es lo que dice ser) y trazabilidad (capacidad de reconstruir el quién, qué, cuándo y cómo de cualquier acción sobre la información).

La **autenticidad** es especialmente relevante en el contexto de deepfakes y phishing generado por IA: el 35% de las brechas con componente IA en 2025 utilizaron deepfakes (IBM). La capacidad de verificar criptográficamente la autenticidad de una comunicación o documento es, en este entorno, una medida de integridad y confidencialidad simultáneamente.

La **trazabilidad** es el fundamento del modelo de responsabilidad: no solo para la atribución forense en caso de incidente, sino para el cumplimiento con DORA, NIS2 y los principios de accountability del RGPD.

BLOQUE 5-6: CUMPLIMIENTO Y CULTURA

La Normativa como Catalizador, No como Fin

El cumplimiento normativo no es un sinónimo de seguridad. Es posible estar certificado en ISO 27001 y sufrir una brecha significativa (los controles deben implementarse y mantenerse, no solo documentarse). También es posible tener una postura de seguridad sólida sin certificación formal. Sin embargo, los marcos normativos proveen algo invaluable: un lenguaje común, un mínimo compartido y una estructura de auditoría que obliga a la verificación externa.

Las preguntas del Bloque 5 no buscan identificar si las organizaciones "pasaron el examen normativo". Buscan entender qué marcos han servido como catalizadores de mejora real.

El Factor Humano: El 60% del Problema

El 60% de las brechas globales en 2025 involucran el factor humano (Verizon DBIR 2025). Esta estadística, consistente año tras año, no es una acusación a los empleados: es una indicación de que los controles técnicos son necesarios pero insuficientes si no van acompañados de una cultura de seguridad genuina.

La pregunta P6.3 sobre reportes de empleados es un proxy de cultura: las organizaciones donde los empleados reportan incidentes activamente tienen, en promedio, menor tiempo de detección y contención. El miedo a las represalias, mencionado en la última opción de P6.3, es el mayor destructor de esta cultura.

BLOQUE 7: TECNOLOGÍA AVANZADA — EL FUTURO QUE YA LLEGÓ

Las preguntas de este bloque abordan tendencias que en 2022 eran "emergentes" y en 2025 son operativas. La computación cuántica no es ciencia ficción: los estándares PQC del NIST (agosto 2024) son una respuesta institucional a una amenaza que los servicios de inteligencia occidentales consideran real y con horizonte temporal definido.

La pregunta P7.3 sobre Zero Trust incluye una opción que, con toda su ironía literaria, refleja una realidad documentada: "Zero Trust es un término que usamos en las presentaciones al Consejo con distinta frecuencia que en la realidad técnica." La brecha entre el discurso Zero Trust y la implementación real es uno de los hallazgos más consistentes del Cisco Cybersecurity Readiness Index 2025.

La medición del ROI en ciberseguridad (P7.4) es la pregunta que más incomoda a los CISO y más interesa a los CFO. El modelo FAIR (Factor Analysis of Information Risk), con una tasa de adopción del 45% entre organizaciones avanzadas, es la respuesta metodológica más robusta disponible. Su integración en los informes al Consejo de Administración es el paso hacia la profesionalización definitiva de la función de seguridad.

Narrativa Explicativa CIA Triad Survey Kit v2025 · Basada en: INCIBE Balance 2025, ENISA TL 2025, Verizon DBIR 2025, IBM Cost of Data Breach 2025, Cisco CRI 2025, NIST CSF 2.0, ENS RD 311/2022, FAIR Institute 2025